HACKATHON FP SAMPOL · RETO SOC · EQUIPO 2

Informe final del incidente y de la solución SOC

Qué ha pasado, cuánto puede costar a la empresa, qué hemos construido y qué recomendamos. Cada cifra indica su origen: [D] dato del director, [BD] base de datos del equipo, [H] hipótesis del equipo.

Fecha	04/11/2026 09:28 (hora de Madrid)
Equipo	Equipo 2 (5 personas)
Anexos	A · Evidencias del buzón · B · Metodología y fuentes
Material adjunto	Diapositivas e infografías de la base de datos, de la cadena Moreno y del informe (PDF)

1. Resumen ejecutivo

- **Qué ha pasado.** Una intrusión ha saltado de cuenta en cuenta: **12 cuentas** `*moreno` en **12 equipos de 6 sedes** (Barcelona, Bilbao, Madrid, Palma, Sevilla, Valencia), una nueva cada ~74 min. Todas llegan a la fase de impacto: ficheros alterados o perdidos. En paralelo, el director informa de un ransomware con **doble extorsión**, **18 GB enviados a una IP externa**, copias de seguridad debilitadas y un **documento de pagos manipulado**.
- **Cuánto puede costar.** Entre **331.120 €** y **1.328.400 €** (escenario medio: **662.280 €**). Lo que más pesa es la parada del servicio, a 25.000 €/h [D]. A eso se suman una posible sanción (hasta el 4 % de la facturación o 20 M€ por el RGPD) y el fraude en pagos, cuyo importe está pendiente.
- **Qué hemos construido.**
- **Base de datos:** recibe el buzón, clasifica las alertas con la taxonomía INCIBE y detecta duplicados, inconsistencias y correos manipulados (257 correos procesados).
- **Bloqueo automático:** AUTO-05 bloquea con alerta crítica verificada. AUTO-06 bloquea por correlación al detectar la cuenta comprometida, **37-55 min antes** de la primera alerta crítica, con 0 falsos positivos en la simulación sobre el histórico (no hay bloqueos ejecutados que lo confirmen).
- **Valor económico:** el coste **evitable estimado** con AUTO-06 es de **280.000 €** en el escenario medio [H]. Es una estimación contrafactual, no un ahorro realizado.
- **Qué no ha funcionado.** La API de bloqueo rechaza la clave del equipo (401) desde la noche del 03/11 y la organización no la repondrá. La causa no está confirmada; una hipótesis es el intento de reenviar la ficha de credenciales a una cuenta externa (12:30). Hay **16 bloqueos en cola y 0 ejecutados** por el equipo. La contención real la hizo Infra: según el director, a las 5:30 el ataque estaba bloqueado y el servidor aislado.

2. Qué hicimos durante el reto (cronología)

Hora	Hito
03/11 mañana	Lectura del reto, conexión con PostgreSQL de Azure y con la API; esquema 001-004 (bandeja inmutable, alertas, taxonomía INCIBE, 39 reglas)
03/11 tarde	Ingesta del buzón (Power Automate → Sites → GitHub Actions → BD); panel web del equipo; organización con contrato de BD y buzón de coordinación
03/11 18:00-20:00	Directriz del director: automatizar bloqueos → migraciones 005-006 (bloqueo de nivel 2 y analítica por franjas)
03/11 21:30-23:00	Diagnóstico: 0 bloqueos posibles, extracción rota y API en 401 → migraciones 007 (extracción HTML), 008-010 (autenticidad por cabeceras de Exchange, regla AUTO-05)
03/11 23:00-00:00	Investigación: cadena *moreno → migraciones 011-013 (fases del ataque, AUTO-06, corrección de corroboración); línea temporal para el jurado
04/11 madrugada	Organización de Outlook (011 del compañero + 015/016), carpetas y flujo de Power Automate; respuestas a las directrices de crisis del director
04/11 mañana	Simulador de bloqueos etiquetado (sin clave real); correcciones de la revisión WEB-008 → migraciones 017 (AUTO-06 con fases previas auténticas) y 018 (KPIs sin simulación); informe, infografías y presentación

Migraciones aplicadas en Azure: 18 (001-018; 21 registros, porque 3 se renumeraron al llegar la organización de Outlook).

3. Costes para la empresa

3.1 Impacto del ransomware (por sede y equipo afectados)

Base: **6 sedes** y **12 equipos** en fase de impacto [BD], más 4 servidores LAB citados por el director (LAB-FS-01, LAB-APP-04, LAB-BKP-02, LAB-WS-17). Hora de servicio parado: 25.000 €/h [D]; analista 45 €/h [D]; técnico 50 €/h [D].

Concepto	Bajo	Medio	Alto	Origen
Horas de parada por sede	2 h	4 h	8 h	[D] horas del Excel
Parada del servicio (sedes × horas × 25.000 €)	300.000 €	600.000 €	1.200.000 €	[D]+[BD]
Respuesta (analistas por equipo comprometido)	4.320 €	6.480 €	10.800 €	[H] 8/12/20 h por equipo
Restauración (equipos + servidores LAB)	6.800 €	10.800 €	17.600 €	[H] 6/10/16 h y 16/24/40 h
Forense externo y asesoría jurídica	15.000 €	30.000 €	60.000 €	[H]
Notificación y comunicación a afectados	5.000 €	15.000 €	40.000 €	[H]
Total estimado	**331.120 €**	**662.280 €**	**1.328.400 €**	

No incluido (exposición sin cuantificar): - **Fraude en pagos:** documento con la cuenta de destino cambiada (alerta AL-20261030-0121 y correo del director de las 3:46); el importe es desconocido. - **Rescate:** doble exigencia, no se recomienda pagar. - **Sanciones:** RGPD art. 83.5, hasta 20 M€ o el 4 % de la facturación anual; NIS2 art. 34, hasta 10 M€ o el 2 % para entidades esenciales del sector energético. - **Daño reputacional y pérdida de contratos.**

3.2 Coste evitable estimado con la detección temprana (AUTO-06, contrafactual)

En 8 de las 12 víctimas (vía robo de credenciales), AUTO-06 detecta la cuenta comprometida **entre 37 y 55 min antes** que la primera alerta crítica [BD]. Si el bloqueo se hubiera ejecutado entonces, se habría evitado la parada de esa parte de la cadena con una efectividad del 50/70/90 % [H]:

	Bajo	Medio	Alto
Coste evitable estimado (contrafactual)	100.000 €	280.000 €	720.000 €

3.3 Coste del SOC manual

- 3000 alertas al mes × 12 min × 45 €/h [D] = **27.000 €/mes**; bloqueos manuales 120 × 25 min = 2.250 €/mes. **Total: 29.250 €/mes (351.000 €/año).**
- En el buzón real, el **52% de las alertas llega en guardia de noche** (22:00-08:00), con 18 críticas [BD]. Es la franja más cara y la que tiene menos personal.
- Ruido real medido: **24.5%** de los correos (63 de 257: duplicados, informativos, no SOC y malformados) [BD]. El Excel usa un 63,2 % de ejemplo (hoja «DatosBD», datos inventados pendientes de sustituir).

3.4 Retorno de nuestra solución

Hipótesis prudentes del análisis económico revisado (04/11): 400 h de desarrollo e implantación, infraestructura y soporte mensuales, y solo la mitad de las horas liberadas se cuenta como ahorro [H].

Indicador	Excel (realista)	Recalculado con el ruido real
Inversión inicial	20.000 €	20.000 €
Ahorro neto mensual	5.649 €	3.852 €

Indicador	Excel (realista)	Recalculado con el ruido real
Periodo de recuperación	3,5 meses	5,2 meses
ROI del primer año (solo tiempo)	140,9 %	77 %
ROI del primer año (tiempo + coste evitado)	190,3 %	—

Con el ruido real medido (24.5%), hay menos alertas que filtrar y el ahorro es menor: la inversión se recupera en unos 5 meses en lugar de 3,5 meses. A 3 años, la opción financieramente mejor según la hoja «Comparativa» es **Construir (propia)**: coste total 61.760 € frente a 216.200 € de un SIEM/SOAR comercial (60.000 €/año + 20.000 € de implantación [D]). Las horas liberadas se reasignan a investigación, no a reducir plantilla.

Retorno del bloqueo automático (hoja «Automatización», directriz del director de las 0:03; 120 bloqueos manuales al mes de 25 min [D]):

Escenario	Ahorro anual en tiempo	Coste evitado anual	Inversión del módulo	Recuperación	ROI 1.er año
Prudente	4.320 €	1.440 €	4.000 €	13,3 meses	−6,5 %
Realista	9.504 €	11.520 €	3.000 €	1,9 meses	355,1 %
Optimista	14.904 €	51.840 €	2.000 €	0,4 meses	2067,0 %

El escenario optimista no se usa para decidir. Con salvaguardas (lista blanca, aprobación humana en activos críticos, registro y botón de liberar), el módulo se paga en unos 2 meses en el escenario realista.

4. Análisis forense

4.1 La cadena *moreno

- **Origen conocido:** jmoreno@sampol.com (srv-barcelona-201). Un correo con formulario falso → fuerza bruta → acceso no reconocido.
- **Propagación:** una cuenta y un equipo nuevos cada ~74 min de aviso; numeración de equipos consecutiva (201 → 212); sedes en rotación (Barcelona, Bilbao, Madrid, Palma, Sevilla, Valencia).
- **Dos vías de entrada que se alternan:**
- Robo de credenciales: phishing → fuerza bruta → acceso no reconocido → lectura → mando y control → impacto.
- Explotación del equipo: sondeo de puertos → petición con explotación → proceso anómalo → mando y control → impacto.
- **Siguiente víctima estimada:** hacia las 05:23 (hora de aviso). **No ha llegado:** coincide con el aislamiento que hizo Infra a las 5:30. Ya en cola automáticamente y sin cadena completa todavía: hmartinez@sampol.com, jfernandez@sampol.com, pgonzalez@sampol.com.

#	Cuenta	Equipo	Sede	IP relacionada	Primer aviso	Fases	Fase máxima	Detección temprana	Bloqueo
1	jmoreno@sampol.com	srv-barcelona-201	Barcelona	203.0.113.150	03/11 14:40	6	Impacto (cifrado / pérdida)	+39 min	PENDIENTE (AUTOMATICO)
2	amoreno@sampol.com	pc-sevilla-202	Sevilla	192.0.2.151	03/11 15:33	5	Impacto (cifrado / pérdida)	— (vía explotación)	PENDIENTE (AUTOMATICO)

#	Cuenta	Equipo	Sede	IP relacionada	Primer aviso	Fases	Fase máxima	Detección temprana	Bloqueo
3	cmoreno@sampol.com	app-valencia-203	Valencia	198.51.100.152	03/11 16:49	6	Impacto (cifrado / pérdida)	+41 min	PENDIENTE (MANUAL)
4	bmoreno@sampol.com	gw-bilbao-204	Bilbao	203.0.113.153	03/11 18:01	6	Impacto (cifrado / pérdida)	+44 min	PENDIENTE (AUTOMATICO)
5	dmoreno@sampol.com	srv-palma-205	Palma	192.0.2.154	03/11 19:08	5	Impacto (cifrado / pérdida)	— (vía explotación)	PENDIENTE (AUTOMATICO)
6	emoreno@sampol.com	pc-madrid-206	Madrid	198.51.100.155	03/11 20:39	6	Impacto (cifrado / pérdida)	+43 min	PENDIENTE (MANUAL)
7	fmoreno@sampol.com	app-barcelona-207	Barcelona	203.0.113.156	03/11 21:51	6	Impacto (cifrado / pérdida)	+46 min	PENDIENTE (MANUAL)
8	gmoreno@sampol.com	gw-sevilla-208	Sevilla	192.0.2.157	03/11 23:16	5	Impacto (cifrado / pérdida)	— (vía explotación)	PENDIENTE (MANUAL)
9	hmoreno@sampol.com	srv-valencia-209	Valencia	198.51.100.158	04/11 00:25	6	Impacto (cifrado / pérdida)	+40 min	PENDIENTE (AUTOMATICO)
10	imoreno@sampol.com	pc-bilbao-210	Bilbao	203.0.113.159	04/11 01:39	6	Impacto (cifrado / pérdida)	+55 min	PENDIENTE (AUTOMATICO)
11	vmoreno@sampol.com	app-palma-211	Palma	192.0.2.160	04/11 02:57	5	Impacto (cifrado / pérdida)	— (vía explotación)	PENDIENTE (AUTOMATICO)
12	lmoreno@sampol.com	gw-madrid-212	Madrid	198.51.100.161	04/11 04:09	6	Impacto (cifrado / pérdida)	+37 min	PENDIENTE (AUTOMATICO)

Las IPs sin puntos del correo original (p. ej. `2030113150`) se han reconstruido como 203.0.113.150. Todas pertenecen a rangos de documentación (TEST-NET).

4.2 Indicadores y hechos del incidente (correos del director)

- **LAB-FS-01**: archivos `.locked` y nota de rescate (1:05).
- **LAB-WS-17**: sesión activa contra LAB-FS-01; desfase horario de 11 min (1:21, 2:25).
- **LAB-APP-04**: 18 GB hacia **198.51.100.77**, `auditoria_2026.7z`, tarea «System Health Check» y herramienta remota sin validar (1:53, 2:41).
- **LAB-BKP-02**: retención de copias reducida; la identidad investigada tenía permisos (2:57).

- `ejercicio.backup`: escrituras fuera de su origen habitual (1:21, 2:25).
- Doble extorsión: descifrado y no publicación; muestra con la marca «Escenario ficticio» y un dominio `.invalid` (1:37, 3:13).
- Hipótesis de acceso inicial del director: soporte remoto no validado, credenciales expuestas o archivo por correo (4:34).

4.3 Otros casos relevantes

Alerta	Cuenta	Equipo	Gravedad	Hecho	Aviso
AL-20261030-0098	rperez@sampol.com	pc-madrid-098	CRITICO	Uso confirmado de cuenta administrativa desde origen no autorizado	03/11 10:19
AL-20261030-0107	fgomez@sampol.com	app-valencia-107	ALTO	Captura de tráfico sin autorización de cambio	03/11 10:42
AL-20261030-0108	ggomez@sampol.com	gw-bilbao-108	MEDIO	Llamada intenta obtener información del equipo	03/11 10:43
AL-20261030-0112	lgomez@sampol.com	gw-sevilla-112	ALTO	Equipo sustraído de zona restringida	03/11 11:04
AL-20261030-0118	rgomez@sampol.com	pc-sevilla-118	ALTO	Datos perdidos tras avería de almacenamiento	03/11 11:43
AL-20261030-0121	jfernandez@sampol.com	srv-palma-121	ALTO	Suplantación solicita cambio de cuenta de pago	03/11 12:07
AL-20261030-0129	hfernandez@sampol.com	srv-barcelona-129	CRITICO	Investigación confirma persistencia dirigida en el proyecto	03/11 13:17
AL-20261030-0175	ogonzalez@sampol.com	app-palma-015	ALTO	Captura de tráfico sin autorización de cambio	03/11 17:31
AL-20261030-0042	cmoreno@sampol.com	app-valencia-203	ALTO	Datos perdidos tras avería de almacenamiento	03/11 18:41
AL-20261030-0210	ilopez@sampol.com	pc-bilbao-050	MEDIO	Llamada intenta obtener información del equipo	03/11 21:40
AL-20261030-0060	emoreno@sampol.com	pc-madrid-206	ALTO	Datos perdidos tras avería de almacenamiento	03/11 22:31
AL-20261030-0078	hmoreno@sampol.com	srv-valencia-209	ALTO	Datos perdidos tras avería de almacenamiento	04/11 02:09
AL-20261030-0254	nperez@sampol.com	pc-madrid-094	ALTO	Datos perdidos tras avería de almacenamiento	04/11 03:04
AL-20261030-0265	dgomez@sampol.com	srv-palma-105	CRITICO	Investigación confirma persistencia dirigida en el proyecto	04/11 04:27
AL-20261030-0096	lmoreno@sampol.com	gw-madrid-212	ALTO	Datos perdidos tras avería de almacenamiento	04/11 05:30
AL-20261030-0299	sfernandez@sampol.com	app-valencia-139	CRITICO	Investigación confirma persistencia dirigida en el proyecto	04/11 06:28
AL-20261030-0316	prodriguez@sampol.com	gw-sevilla-156	ALTO	Equipo sustraído de zona restringida	04/11 07:02
AL-20261030-0325	dgonzalez@sampol.com	srv-palma-005	ALTO	Suplantación solicita cambio de cuenta de pago	04/11 07:22
AL-20261030-0336	pgonzalez@sampol.com	gw-bilbao-016	CRITICO	Uso confirmado de cuenta administrativa desde origen no autorizado	04/11 07:35

Alerta	Cuenta	Equipo	Gravedad	Hecho	Aviso
AL-20261030-0346	emartinez@sampol.com	pc-sevilla-026	MEDIO	Llamada intenta obtener información del equipo	04/11 08:00
AL-20261030-0356	pmartinez@sampol.com	gw-madrid-036	ALTO	Datos perdidos tras avería de almacenamiento	04/11 08:17
AL-20261030-0370	ilopez@sampol.com	pc-sevilla-050	CRITICO	Uso confirmado de cuenta administrativa desde origen no autorizado	04/11 08:53
AL-20261030-0380	tlopez@sampol.com	gw-madrid-060	MEDIO	Llamada intenta obtener información del equipo	04/11 08:58
AL-20261030-0390	isanchez@sampol.com	pc-bilbao-070	ALTO	Datos perdidos tras avería de almacenamiento	04/11 09:05

Compromisos aislados, sin cadena previa (AUTO-06 los descarta y quedan para revisión humana): ilopez@sampol.com, mgonzalez@sampol.com, ngonzalez@sampol.com, ogonzalez@sampol.com, osanchez@sampol.com, pgonzalez@sampol.com, sperez@sampol.com.

Incidente interno: el 03/11 a las 12:30, la cuenta del equipo intentó reenviar la ficha de credenciales a una Gmail personal. La regla de transporte lo bloqueó. Después la API empezó a rechazar la clave; la relación entre ambos hechos es una hipótesis, no está confirmada (ver anexo A).

4.4 Impacto para la empresa

- **Disponibilidad:** 12 equipos y servidores de ficheros, aplicaciones y copias comprometidos en 6 sedes; reapertura condicionada a identidades verificadas.
- **Confidencialidad:** posible extracción (18 GB) de contratos, información financiera y expedientes de personal, propios y de terceros. Obliga a valorar notificar en 72 h (RGPD).
- **Integridad:** documento de pagos alterado y copias con retención reducida. No hay RTO/RPO acordados.
- **Recuperabilidad:** sin una restauración reciente probada; las copias no son fiables hasta validarlas en un entorno aislado.

4.5 Respuesta al director: de dónde viene, cómo llegó y qué hacer (correo de las 8:07)

- **De dónde viene (confirmado en los datos):** de una infraestructura externa. Las IPs relacionadas con la cadena están en rangos de documentación (192.0.2.x, 198.51.100.x, 203.0.113.x) y la posible salida de datos fue hacia 198.51.100.77. La atribución a un actor concreto no está confirmada.
- **Cómo llegó (dos vías observadas en cada víctima):** 1) **robo de credenciales**: correo con formulario falso → fuerza bruta → acceso no reconocido; 2) **explotación del equipo**: sondeo de puertos → petición con patrón de explotación → proceso anómalo. El acceso inicial de la intrusión que llega a LAB-FS-01 sigue abierto entre tres hipótesis del director (soporte remoto no validado, credenciales expuestas, archivo por correo). La que más encaja con nuestros datos es la de credenciales robadas por phishing (8 de 12 víctimas empiezan así; el resto, por explotación del equipo), pero falta la prueba que la confirme.
- **Qué hacer:** ver §7. En el orden de prioridad: revocar sesiones y credenciales de las cuentas *moreno, aislar los LAB-* afectados, bloquear 198.51.100.77, restaurar desde copias verificadas y reforzar el MFA y el filtrado de phishing.
- **Contención real:** a las 5:30 el director informó de que Infra había bloqueado el ataque y aislado el servidor. Los bloqueos de usuario del equipo siguen en cola (API en 401).

5. Respuesta y controles implantados

- **Bloqueo automático (BD):** AUTO-05 (crítico verificado) y AUTO-06 (correlación). Decisiones: AUTO-05 BLOQUEAR USUARIO=10, AUTO-05 RECOMENDAR IP=17, AUTO-05 RECOMENDAR USUARIO=5, AUTO-05 YA_BLOQUEADO USUARIO=18, AUTO-06 BLOQUEAR USUARIO=2, AUTO-06 DESCARTAR USUARIO=7, AUTO-06 YA_BLOQUEADO USUARIO=6.
- **Cola de bloqueos:** 16 pendientes, 1 omitida (falso positivo corregido) y 0 ejecutados (API en 401).
- **Autenticidad del remitente:** SPF pass de protection.outlook.com, AuthAs Internal y SHA-256 del original. Las directrices solo valen de dirti@.
- **Demostración (simulador local con el mismo contrato que la API): 13 bloqueos ejecutados y verificados y 1 liberación(es) en un clic. Es una SIMULACIÓN: sin clave válida no hay contención por API; la contención real la hizo Infra (5:30).** Comandos: `demo/bloqueador_simulado.py` y `demo/demo_bloqueos.py`; las filas llevan `simulacion = TRUE` y no afectan a la cola real.
- **Buzón:** 10 carpetas y un flujo de Power Automate que ordena cada correo nuevo 5 min después de que lo capture la ingesta.
- **Directrices de crisis:** todas respondidas. La reapertura (5:58) y la primera evaluación de la solicitud externa (6:01) salieron fuera de plazo; la causa inicial se amplió y corrigió a las 5:59 (`docs/directrices.md`).

6. Lo que no salió bien y lecciones aprendidas

- **La ficha con credenciales se intentó reenviar a una Gmail desde la cuenta del equipo; después la API rechazó la clave (relación no confirmada).** → Las credenciales solo en `.env` y gestores de secretos; nunca reenviar fichas. Tratar cualquier exposición como un compromiso y pedir rotación por un canal seguro.
- **0 bloqueos ejecutados: 16 decisiones quedaron en cola.** → Tener una vía alternativa para contener (manual con registro) y vigilar la salud de la API (401) con una alarma.
- **La extracción de campos estaba rota (usuario «relacionada» en 110/110) hasta la migración 007.** → Probar con correos reales desde el principio, no solo con datos sintéticos.
- **La corroboración contaba los reenvíos como alertas nuevas (falso positivo de slopez).** → Contar por identificador de alerta; las pruebas de regresión antes de activar reglas que bloquean.
- **La ingesta dependía de un cron de GitHub que no se ejecutaba solo.** → Ingesta directa de Power Automate a la BD y monitorizar el retraso (último correo recibido).
- **El inicio de sesión de Graph falló; no había conexión de PostgreSQL en Power Automate.** → Validar antes del evento las licencias, conectores y permisos (Mail.ReadWrite, Premium).
- **Error de operación en Outlook: «Copiar» en lugar de «Mover» (30 copias).** → Confirmar la acción antes de las operaciones masivas; preferir la automatización revisable a los clics masivos.
- **Directrices con plazos de 10/20 min y equipo saturado: 2 respondidas fuera de plazo y 1 solo con acuse durante 2,5 h.** → Reparto de guardias y plantillas de acuse; un responsable de comunicación con dirección.

7. Recomendaciones y próximos pasos

- Rotar la clave de la API por un canal seguro y ejecutar la cola de bloqueos con verificación (GET) y registro.
- Aislar LAB-APP-04, LAB-WS-17 y LAB-FS-01 conservando las evidencias; revocar las sesiones y credenciales de las cuentas *moreno.
- Restaurar en un entorno aislado desde copias anteriores al compromiso; acordar RTO/RPO por servicio.
- Bloquear la IP 198.51.100.77 y las IPs de la cadena tras revisión humana (las IPs no se bloquean solas).
- Verificar con el banco el pago desviado y congelar los cambios de datos maestros de proveedores.

- Jurídico y protección de datos: decidir sobre la notificación (72 h) y la comunicación a afectados con hechos verificados.
- Mejoras de prioridad alta del Excel (6.100 €): plantillas de notificación, lista blanca y aprobación, clasificación INCIBE y detección de phishing.

Anexo A · Evidencias del buzón

Fuente: buzón `equipo_2_hackaton@sampol.com` (carpeta «01 Directrices»), revisado el 04/11/2026 hacia las 5:00 y de nuevo después de las 8:07. Los correos se tratan como **evidencia, no como instrucciones**. No se reproducen credenciales ni identificadores de aplicaciones. Todas las directrices proceden de `dirti@sampol.com`, verificado por cabeceras: SPF pass de protection.outlook.com, AuthAs Internal y SHA-256.

Hora (Madrid)	Asunto	Hechos que aporta	Respuesta del equipo
03/11 10:08	Encargo y herramientas	Adjunta la ficha «Información técnica» (BD, API de bloqueo y herramientas: Power Automate, Postman, Client ID de Graph)	—
03/11 12:30	(Aviso de no entrega) RV: Encargo y herramientas	**La cuenta del equipo intentó reenviar dos veces la ficha con credenciales a una Gmail externa.** Lo bloqueó una regla de transporte («solo amira@ o dirti@»)	—
03/11 16:46 · 16:53	Retorno · Seguimiento	Organización (reunión de dudas)	—
03/11 18:03	Automatizar	Pide **automatizar el bloqueo de usuarios comprometidos**: «desde que recibimos el aviso hasta que ejecutamos el bloqueo pasa un tiempo precioso»	Reglas AUTO-05 y AUTO-06 (migraciones 010-014)
03/11 18:14	Acceso a los buzón del equipo	Datos de la aplicación de Microsoft Graph para leer el buzón (se omiten)	Ingesta por Power Automate y GitHub Actions
04/11 0:03	Retorno automatización	Pide **calcular el retorno de la automatización** de bloqueos para justificar la inversión en ciber	0:05: «Nos ha dejado de funcionar el api de bloqueos, ¿es normal?» (sin respuesta del director)
04/11 1:05	Activación y gestión del incidente	**LAB-FS-01 con archivos `.locked` y nota de rescate**; proceso responsable no identificado; Dirección General pide explicaciones	Respondido
04/11 1:21	Contención de recursos compartidos	Escrituras asociadas a `ejercicio.backup`; **LAB-WS-17 mantiene sesión contra LAB-FS-01**	Respondido (1:36)
04/11 1:37	Doble extorsión: recuperación y confidencialidad	**Dos exigencias económicas** (descifrado + no publicar). Afirman tener contratos, información financiera y archivos de personal (no verificado). Nadie debe negociar	«Primera evaluación» (1:43)
04/11 1:53	Investigación de posible extracción	**LAB-APP-04 envía 18 GB a 198.51.100.77**; en la misma ventana se crea `auditoria_2026.7z` (relación no demostrada)	Respondido (2:08): los 18 GB no confirman qué documentos salieron
04/11 2:09	Evaluación de datos personales	El índice recibido incluye personal, proveedores y contratos	Respondido (2:26)

Hora (Madrid)	Asunto	Hechos que aporta	Respuesta del equipo
04/11 2:25	Cronología e identidad técnica	Horarios incoherentes entre fuentes (**desfase de 11 min en LAB-WS-17**); `ejercicio.backup` fuera de su origen habitual (LAB-BKP-02)	Respondido (2:40): normalizar a UTC
04/11 2:41	Verificación de acceso persistente	El atacante afirma seguir dentro; **LAB-APP-04: tarea «System Health Check» y herramienta remota sin validar**; conoce una carpeta creada después del aviso	Respondido (2:58): persistencia sin confirmar
04/11 2:57	Validación de copias y restauración	**LAB-BKP-02: copia «correcta» pero con retención reducida**; sin restauración reciente; la identidad investigada tenía permisos	Respondido (3:06 y 3:14): no hay RTO/RPO acordados
04/11 3:13	Verificación de supuesta publicación	Mensaje del atacante: «hemos cifrado sus sistemas y copiamos sus archivos… la primera muestra está preparada». La captura incluye la marca «Escenario ficticio» y un dominio `.invalid`	Respondido (3:28): no se confirma publicación
04/11 3:30	Solicitud externa no verificada	**Vishing**: llamada que suplanta a un directivo y pide inventario y muestra para una dirección externa	Acuse (3:41); primera evaluación enviada por ChatGPT a las 6:01, fuera de plazo (ver `docs/directrices.md`)
04/11 3:46	Integridad de documentos de pagos	**Documento de pagos con la cuenta de destino cambiada**; la fecha coincide parcialmente con el incidente	Respondido (4:15); vinculado a AL-20261030-0121 (suplantación que pide cambiar la cuenta de pago, jfernandez@, srv-palma-121)
04/11 4:02	Relación de afectados y comunicaciones	El índice mezcla empleados, contactos y contratos, con datos propios y de terceros; pide un plan de comunicaciones	Respondido (4:17)
04/11 4:18	Criterios de reapertura de servicios	Un servicio funciona aislado pero **usa una identidad investigada**; pide una matriz de reapertura	Matriz de reapertura enviada por ChatGPT a las 5:58, fuera de plazo
04/11 4:34	Análisis de la causa inicial	Tres hipótesis abiertas: **soporte remoto no validado, credenciales expuestas, archivo recibido por correo**	Acuse y respuesta automáticos (4:34); ampliación correctiva enviada por ChatGPT a las 5:59
04/11 4:50	Informe consolidado del ejercicio	Pide reconstruir cómo ocurrió, cómo se detectó, qué se hizo y qué hacer después. «**No inventen certezas ni den por ejecutadas medidas que solo se propusieron**»	Este informe (`INFORME.md`)
04/11 5:30	Servicio Aislado	**Infra ha bloqueado el ataque y el servidor está aislado** (contención realizada por Infra, no por la automatización del equipo)	Informativo
04/11 8:07	Análisis Forense	Pide saber **de dónde viene el ataque, cómo ha llegado y qué se puede hacer** («Investigación y creatividad»)	Secciones 4 y 7 de este informe

Cronología de la API de bloqueo

- 03/11 hacia las 13:00-15:00: la clave de la ficha funcionaba (GET `/equipo-2/bloqueos` → 200).
- 03/11 12:30: intento de reenviar la ficha (con la clave) a una Gmail externa.
- 03/11 22:30 (hora de Madrid) como tarde: la API responde **401 «Contraseña de equipo incorrecta o ausente»** con la clave de la ficha, coincidente byte a byte con el PDF.

- 04/11 0:05: el equipo pregunta al director; sin respuesta registrada.
- **Hipótesis, no confirmada:** la clave pudo revocarse por la exposición de la credencial. La regla de transporte paró el envío. El 401 solo confirma que la API rechaza la credencial, no la causa. La organización ha confirmado que no repondrá la clave.

Anexo B · Metodología y fuentes

- Base de datos del equipo: vistas `v_kpis`, `v_cadena_victimas`, `v_cadena_ransomware`, `v_decisiones_bloqueo`, `v_stats_franja`, entre otras (`db/schema.sql`).
- Análisis económico: `Analisis_economico_Sampol.xlsx` (datos del director en verde; hipótesis en amarillo).
- Sanciones: Reglamento (UE) 2016/679, art. 83; Directiva (UE) 2022/2555 (NIS2), art. 34.
- El informe se regenera con `docs/informe/generar_datos.py` y `docs/informe/generar_informe.py`.